

Part A:

Log on to Netlab: NDG Ethical Hacking- Lab 01

- Tunneling. On your kali box, **after the setup**, we are going to do some tunneling/port forwarding. Kali (our hacker) cannot ping anything. Kali can only SSH to security onion. We will be tunneling everything via SSH so that -from kali i can access web interfaces, etc. This will be one of the trickiest labs yet. **Take your time**. Chart out what you need to do.
- 99.9999 of the commands needed to complete this lab are done on kali (our hacker) NDG Ethical Hacking- Lab 01

SETUP: Change pfSense rules.

1. Test that you can only access Security Onion via SSH
2. you cannot ping or access anything else from Kali
3. setup NAT SSH to Security Onion – set up port forwarding to Security Onion box only

	ID	Proto	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description
☐		IPv4 TCP	*	*	*	22 (SSH)	*	none		Allow SSH Only
☐		IPv4 TCP	*	*	192.168.0.100	22 (SSH)	*	none		NAT Forward SSH to Security Onion
☐		IPv4 *	*	*	*	*	*	none		
☐		IPv4 ICMP	*	*	*	*	*	none		

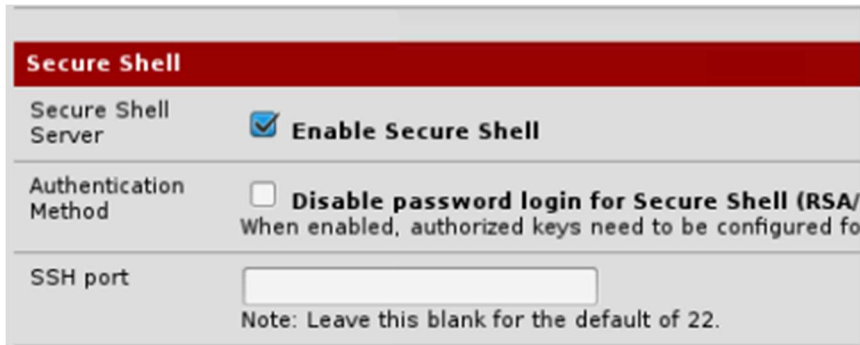
Confirmed that accessing pfsense IP ssh is redirected to security onion:

```
File Edit View Search Terminal Help
root@Kali2:~# ssh student@192.168.9.1
The authenticity of host '192.168.9.1 (192.168.9.1)' can't be established.
ECDSA key fingerprint is b9:22:91:5a:fd:84:a6:fa:30:f4:c4:e8:e0:4d:cd:2b.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '192.168.9.1' (ECDSA) to the list of known hosts.
student@192.168.9.1's password:
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-63-generic x86_64)
```

After ssh was established, I confirmed the IP I was connected to which is security onion's IP:

```
eth1      Link encap:Ethernet  HWa
          inet addr:192.168.0.100
```

Had to also enable secure shell under System > Advanced > Admin Access > Secure Shell section:



Secure Shell

Secure Shell Server ☒ **Enable Secure Shell**

Authentication Method ☐ **Disable password login for Secure Shell (RSA)**
When enabled, authorized keys need to be configured for

SSH port
Note: Leave this blank for the default of 22.

4. In WAN rules pointing to Security Onion, there should only be one rule (your SSH), delete the other rules
Other rules deleted:

Floating

WAN

LAN

DMZ

	ID	Proto	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	
☐	☒	IPv4 TCP	*	*	*	22 (SSH)	*	none		Allow SSH Only	
☐	☒	IPv4 TCP	*	*	192.168.0.100	22 (SSH)	*	none		NAT Forward SSH to Security Onion	

ran dpkg-reconfigure openssh-server command in Kali:

```
root@Kali2: ~
File Edit View Search Terminal Help
root@Kali2:~# dpk-reconfigure openssh-server
bash: dpk-reconfigure: command not found
root@Kali2:~# dpkg-reconfigure openssh-server
insserv: warning: current start runlevel(s) (empty) of script `ssh' overrides LSB defaults (2 3 4 5).
insserv: warning: current stop runlevel(s) (2 3 4 5) of script `ssh' overrides LSB defaults (empty).
root@Kali2:~#
```

I checked the status of port 22 and it wasn't showing under netstat -ant, this is why I decided to manually start ssh by running the command 'sudo systemctl start ssh'. The ssh service displayed as active and running then.

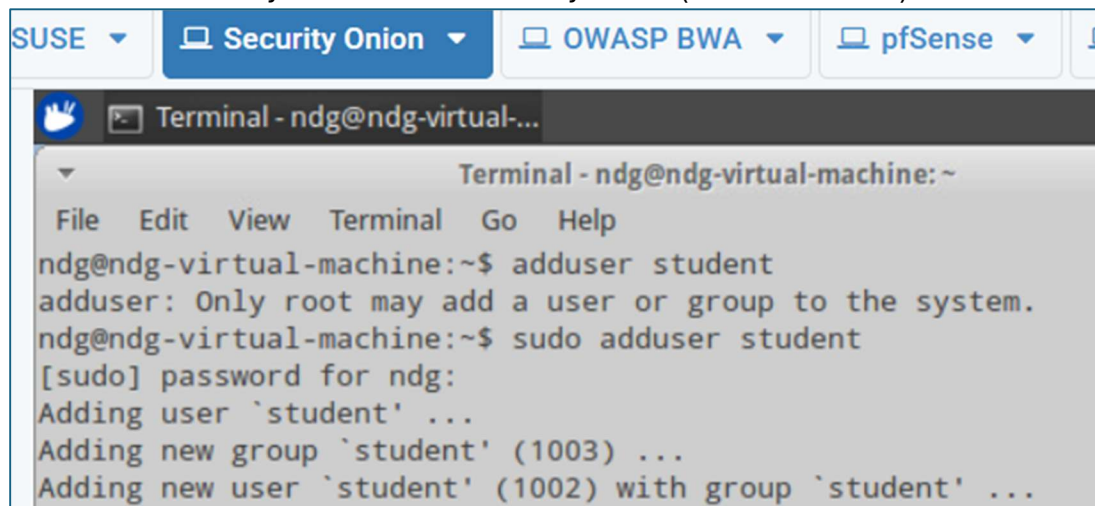
```

root@Kali2:~# systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled)
   Active: active (running) since Wed 2025-10-01 11:16:43 CDT; 7s ago
 Main PID: 1933 (sshd)
   CGroup: /system.slice/ssh.service
           └─1933 /usr/sbin/sshd -D

Oct 01 11:16:43 Kali2 sshd[1933]: Server listening on 0.0.0.0 port 22.
Oct 01 11:16:43 Kali2 sshd[1933]: Server listening on :: port 22.
root@Kali2:~# netstat -ant
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 127.0.0.1:9390          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:9391          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:9392          0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
tcp6       0      0 :::22                   :::*                    LISTEN
root@Kali2:~#

```

5. finally add a user in Security Onion (student/hacker)



The screenshot shows a terminal window titled "Terminal - ndg@ndg-virtual-...". The terminal output is as follows:

```

ndg@ndg-virtual-machine:~$ adduser student
adduser: Only root may add a user or group to the system.
ndg@ndg-virtual-machine:~$ sudo adduser student
[sudo] password for ndg:
Adding user `student' ...
Adding new group `student' (1003) ...
Adding new user `student' (1002) with group `student' ...

```

6. From kali, tunnel security onion web interface via port 22- access on kali

```

root@Kali2:~# ssh -L 8080:192.168.0.100:443 student@192.168.9.1
student@192.168.9.1's password:
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-63-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

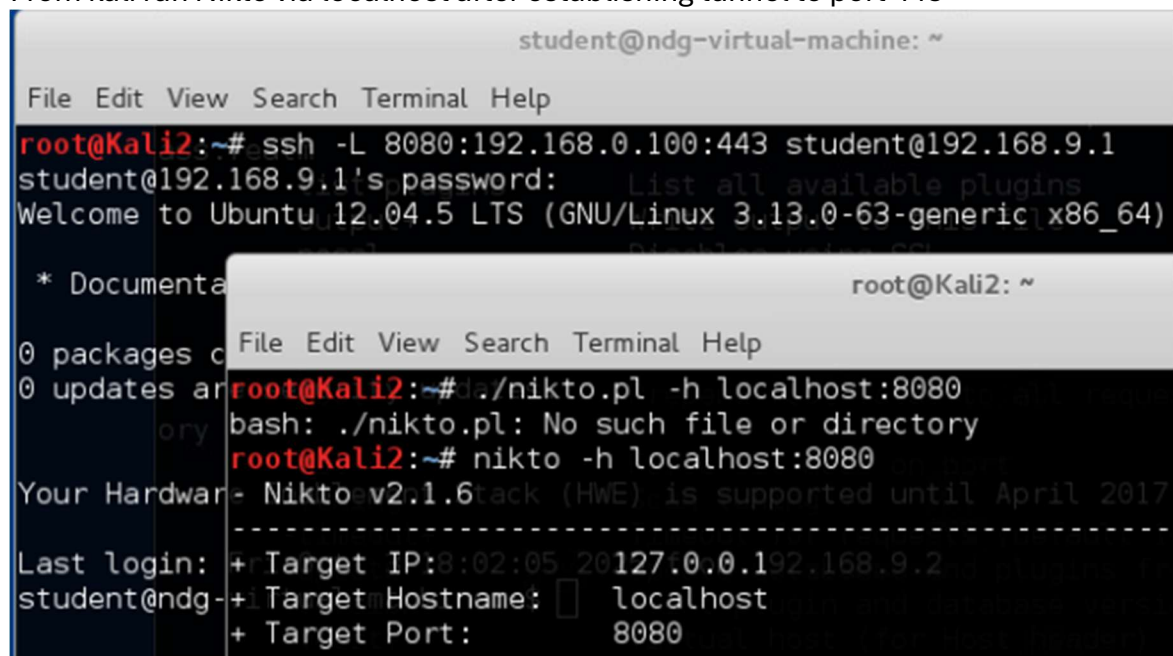
0 packages can be updated.
0 updates are security updates.

Your Hardware Enablement Stack (HWE) is supported until April 2017.

Last login: Fri Oct  3 18:13:36 2025 from 192.168.9.2
student@ndg-virtual-machine:~$

```

7. From kali run Nikto via localhost after establishing tunnel to port 443



```

student@ndg-virtual-machine: ~
File Edit View Search Terminal Help
root@Kali2:~# ssh -L 8080:192.168.0.100:443 student@192.168.9.1
student@192.168.9.1's password:
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-63-generic x86_64)

 * Documenta
0 packages c
0 updates ar
Your Hardwar
Last login:
student@ndg-

root@Kali2: ~
File Edit View Search Terminal Help
root@Kali2:~# ./nikto.pl -h localhost:8080
bash: ./nikto.pl: No such file or directory
root@Kali2:~# nikto -h localhost:8080
Nikto v2.1.6
-----
+ Target IP: 192.168.9.2
+ Target Hostname: localhost
+ Target Port: 8080

```

8. From kali run whatweb via localhost after establishing tunnel to port 443

```
student@ndg-virtual-machine: ~  
File Edit View Search Terminal Help  
root@Kali2:~# ssh -L 8080:192.168.0.100:443 student@192.168.9.1  
student@192.168.9.1's password:  
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-63-generic x86_64)  
New! NAT: Port Forward  
* Documentation: https://help.ubuntu.com/  
Forward 1:1 Outbound NPT  
0 packages can be updated.  
0 updates are security updates.  
WAN TCP: * * WAN address 22 (SSH) 192.168.0.1  
Your Hardware Enablement Stack (HWE) is supported until April 2017.  
Last login: Fri Oct 3 17:40:03 2025 from 192.168.9.2  
student@ndg-virtual-machine:~$
```

9. From kali use dynamic port forwarding and sox proxy to tunnel via port 22 (access browser via ip of security onion and openSUSU)

I set up a proxy with the following command:

Ssh -D 127.0.0.1:9050 [student@192.168.9.1](#) – please see below:

```
student@ndg-virtual-machine: ~  
File Edit View Search Terminal Help  
root@Kali2:~# ssh -D 127.0.0.1:9050 student@192.168.9.1  
student@192.168.9.1's password:  
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-63-generic x86_64)  
* Documentation: https://help.ubuntu.com/  
0 packages can be updated.  
0 updates are security updates.  
Your Hardware Enablement Stack (HWE) is supported until April 2017.  
Last login: Fri Oct 3 18:15:09 2025 from 192.168.9.2  
student@ndg-virtual-machine:~$
```

Confirmed address and port are open: 127.0.0.1:9050

```
root@Kali2: ~  
File Edit View Search Terminal Help  
root@Kali2:~# netstat -ant  
Active Internet connections (servers and establish  
Proto Recv-Q Send-Q Local Address           Foreign Address         State  
tcp        0      0 127.0.0.1:9390         0.0.0.0.*               LISTENING  
tcp        0      0 127.0.0.1:9391         0.0.0.0.*               LISTENING  
tcp        0      0 127.0.0.1:9392         0.0.0.0.*               LISTENING  
tcp        0      0 0.0.0.0:22             0.0.0.0.*               LISTENING  
tcp        0      0 127.0.0.1:9050         0.0.0.0.*               LISTENING  
tcp        0      0 192.168.9.2:45176      192.168.9.2:22         ESTABLISHED  
tcp6       0      0 :::22                  :::*                     LISTENING  
root@Kali2:~#
```

10. after setting up sox proxy, use proxychains to scan for live host

in one window run the following command:

```
student@ndg-virtual-machine: ~  
File Edit View Search Terminal Help  
root@Kali2:~# ssh -D 127.0.0.1:9050 student@192.168.9.1  
student@192.168.9.1's password:  
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-63-generic  
  
* Documentation:  https://help.ubuntu.com/  
  
0 packages can be updated.  
0 updates are security updates.  
  
Your Hardware Enablement Stack (HWE) is supported until Apr  
  
Last login: Fri Oct  3 18:15:09 2025 from 192.168.9.2  
student@ndg-virtual-machine:~$
```

In a separate window run proxychains command below:

```
File Edit View Search Terminal Help  
root@Kali2:~# proxychains nmap -sT 192.168.1.100  
ProxyChains-3.1 (http://proxychains.sf.net)  
  
Starting Nmap 6.49BETA5 ( https://nmap.org ) at 2025-10-03 18:15:09  
mass_dns: warning: Unable to determine any DNS servers  
fy valid servers with --dns-servers  
Note: Host seems down. If it is really up, but blocking  
Nmap done: 1 IP address (0 hosts up) scanned in 1.34 s  
root@Kali2:~# proxychains nmap -sT 192.168.0.100  
ProxyChains-3.1 (http://proxychains.sf.net)
```

Then run “proxychains nmap -sT 192.168.0.100” – this will give you status of ports on the security onion machine

```
|S-chain| -<-127.0.0.1:9050-<-<-192.168.0.100:687-<- -timeout
Nmap scan report for 192.168.0.100
Host is up (0.0012s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
443/tcp    open  https
444/tcp    open  snpp
514/tcp    open  shell
9876/tcp   open  sd
Nmap done: 1 IP address (1 host up) scanned in 1.14 seconds
root@Kali2:~#
```

Additional notes from lecture:

Dynamic Port Forward-Scanning

- `gedit /etc/proxychains.conf`
 - `add- socks5 127.0.0.1 9050`
- `proxychains nmap -sn --unprivileged 192.168.1.0/24`
- `proxychains nc 192.168.1.100`
 - `OPTIONS http://192.168.138.100 http/1.1` (enter e)
- `proxychains nmap -sT --unprivileged 192.168.1.175`
- `proxychains nmap -sS --unprivileged 192.168.1.175`
- `proxychains rdesktop 192.168.1.100`

Dynamic Port Forward-Scanning

- `proxychains nmap -PN -sV -p 80 --script=http-methods --unprivileged 192.168.1.100 -T5`
- `proxychains nikto -h 192.168.1.100`
- `netstat -ant`
- `ps -aux | grep ssh`

11. after setting up sox proxy, use proxychains with whatweb against security onion and openSUSE
could not get proxychains to work in 192.168.1.100 – tried installing it manually but couldn't get to it.
12. set up a tunnel that allows you to view OWASP webpage in kali via security onion. **(tricky one, look at network diagram)**

Established dynamic port forwarding from Kali to Security Onion – please see below:
For this I had to update the firewall redirect of ssh calls to owasp bwa IP address (192.168.0.100)

Command from Kali: `ssh -D 127.0.0.1:9050 student@192.168.9.1`

FYI: proxychain uses port 9050 by default

From Kali, open web browser and enter OWASP BWA IP address: 192.168.68.12



13. using the above configuration, execute whatweb to OWASP and Nikto against OWASP performed nikto scan against OWASP:

whatweb to OWASP:

Opened separate console window in Kali – ran proxychain command:

Proxychains whatweb 192.168.68.12 (OWASP BWA IP address)

```
root@Kali2:~# proxychains whatweb 192.168.68.12
ProxyChains-3.1 (http://proxychains.sf.net)
|S-chain|-<-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
http://192.168.68.12 [200] Apache[2.2.14][mod_mono/2.4.3,mod_perl/2.0.4,mod_python/3.3.1,mod_ssl/2.2.14,proxy_html/3.0.1], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-lubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1], IP[192.168.68.12], OpenSSL[0.9.8k], PHP[5.3.2-lubuntu4.30][Suhosin-Patch], Perl[5.10.1], Phusion_Passenger[4.0.38], Python[2.6.5]
root@Kali2:~#
```

Nikto against OWASP:

Opened separate console window in Kali – ran proxychain command:

Proxychains nikto -h http://192.168.68.12 (OWASP BWA IP address)

```
root@Kali2:~# proxychains nikto -h http://192.168.68.12 soft
ProxyChains-3.1 (http://proxychains.sf.net)gram are described
- Nikto v2.1.6 files in /usr/share/doc/*/copyright.
-----
|S-chain|-<-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK pe
+ Target IP: 192.168.68.12
+ Target Hostname: 192.168.68.12
+ Target Port: virtual-80
+ Start Time: 2025-10-08 12:19:12 (GMT-5)
```

Some results from nikto:

```
+ mod_ssl/2.2.14 appears to be outdated (current is at least 2.8.31) (may depend on server version)
+ proxy_html/3.0.1 appears to be outdated (current is at least 3.1.2)
+ Perl/v5.10.1 appears to be outdated (current is at least v5.14.2)
+ mod_mono/2.4.3 appears to be outdated (current is at least 2.8)
+ OpenSSL/0.9.8k appears to be outdated (current is at least 1.0.1j). OpenSSL 1.0.0o and 0.9.8zc are also current
t.
+ PHP/5.3.2-lubuntu4.30 appears to be outdated (current is at least 5.6.9). PHP 5.5.25 and 5.4.41 are also current
the exact distribution terms for each program are described in the
+ mod_perl/2.0.4 appears to be outdated (current is at least 2.0.7)
+ Python/2.6.5 appears to be outdated (current is at least 2.7.5)
|S-chain|-<-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK permitted by
+ mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1 - mod_ssl 2.8.7 and lower a
re vulnerable to a remote buffer overflow which may allow a remote shell. http://cve.mitre.org/cgi-bin/cvename.c
cgi?name=CVE-2002-0082, OSVDB-756, clear
+ Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
|S-chain|-<-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK connect failed: Connectio
|S-chain|-<-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
+ OSVDB-877: HTTP TRACE method is active, suggesting the host is vulnerable to XST
```

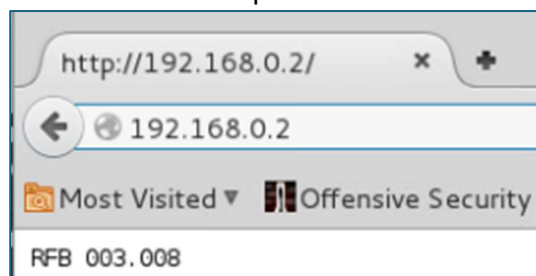
```
+ Retrieved x-powered-by header: PHP/5.3.2-lubuntu4.30
+ Cookie phpbb2owaspbwa_data created without the httponly flag
+ Cookie phpbb2owaspbwa_sid created without the httponly flag
```

```

+ OSVDB-3092: /phpmyadmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or
limited to authorized hosts.
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
+ OSVDB-3268: /test/: Directory indexing found. are described in the
+ OSVDB-3092: /test/: This might be interesting...
+ OSVDB-3092: /cgi-bin/: This might be interesting... possibly a system shell found.
+ OSVDB-3093: /.bash_history: A user's home directory may be set to the web root, the shell history was retrieve
d. This should not be accessible via the web.
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
+ OSVDB-3268: /icons/: Directory indexing found.
+ OSVDB-3268: /images/: Directory indexing found.
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
+ OSVDB-3268: /images/?pattern=/etc/*&sort=name: Directory indexing found.
+ /wordpress/: A Wordpress installation was found.
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
+ /phpmyadmin/: phpMyAdmin directory found
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
+ OSVDB-3092: /phpmyadmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protecte
d or limited to authorized hosts.
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
[S-chain] ->-127.0.0.1:9050-<->-192.168.68.12:80-<->-OK
+ 8497 requests: 1 error(s) and 38 item(s) reported on remote host
+ End Time: 2025-10-08 12:20:02 (GMT-5) (50 seconds)
+ 1 host(s) tested

```

14. From kali tunnel openSUSE web interface via port 22- access on kali



15. From security onion- ssh to kali (outbound connection) **(another tricky one, use your diagram)**. For the next three connections, you are executing your command on the **victim** machine. You can than access the victim from your kali (hacker box)

From **security onion (192.168.0.100)** run the following command:

Ssh -R **3389:192.168.0.100:3389** hacker@192.168.9.2 (this last IP is the IP of the external Kali box)

```
Terminal - hacker@Kali2: ~
File Edit View Terminal Go Help
ndg@ndg-virtual-machine:~$ ssh -R 3389:192.168.0.100:3389 hacker@192.168.9.2
The authenticity of host '192.168.9.2 (192.168.9.2)' can't be established.
ECDSA key fingerprint is 46:b4:b9:23:9b:dd:ef:32:39:69:1d:0f:12:78:20:68.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '192.168.9.2' (ECDSA) to the list of known hosts.
hacker@192.168.9.2's password:

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
hacker@Kali2:~$
```

16. port forward the web-browser from security onion to kali

```
ndg@ndg-virtual-machine:~$ ssh -R 443:192.168.0.100:443 hacker@192.168.9.2
hacker@192.168.9.2's password:
Warning: remote port forwarding failed for listen port 443

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Oct 3 14:06:15 2025 from 192.168.9.1
hacker@Kali2:~$
```

17. port forward the openSUSE web browser from security onion to kali

```
Terminal - hacker@Kali2: ~
File Edit View Terminal Go Help
ndg@ndg-virtual-machine:~$ ssh -R 8080:192.168.0.2:80 hacker@192.168.9.2
hacker@192.168.9.2's password:
Warning: remote port forwarding failed for listen port 8080

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Oct 8 14:02:22 2025 from 192.168.9.1
hacker@Kali2:~$
```

18. port forward the OWASP web browser from security onion to kali

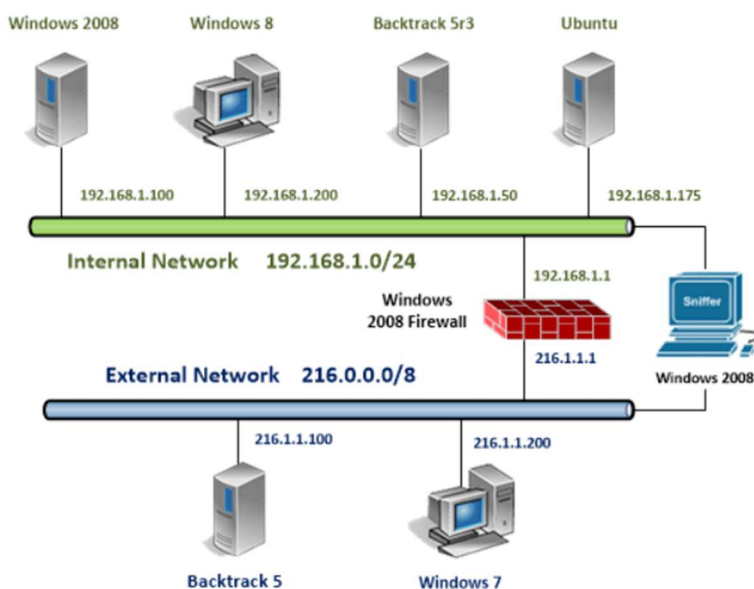
Part B:

Netlab: NISGTC Network Security Setup:

- On the Windows 2008 Firewall, open up port 50000 point the firewall to port 50000 on 192.168.1.200 -the Windows 8 box has this port closed
- On the Windows 2008 Firewall, open up port 50001 point the firewall to port 50001 on 192.168.1.200 -the Windows 8 box has this port closed
- On the Windows 2008 and the Windows 8- disable the firewall
- On the Windows 2008 and the Windows 8 enable RDP
- On the Backtrack internal, add the user hacker with password student
- On the Backtrack internal, run the following command as root: dpkg-reconfigure openssh-server (ensure SSH is running)

Process:

Given the following network map:



In external backtrack:

1. Create hacker user
2. Ran dpkg-reconfigure openssh-server
3. Verified port 22 is open (run netstat -ant to verify)

```
root@bt: ~  
File Edit View Terminal Help  
root@bt:~# adduser student  
Adding user `student' ...  
Adding new group `student' (1002)  
Adding new user `student' (1002) v  
Creating home directory `/home/stu
```

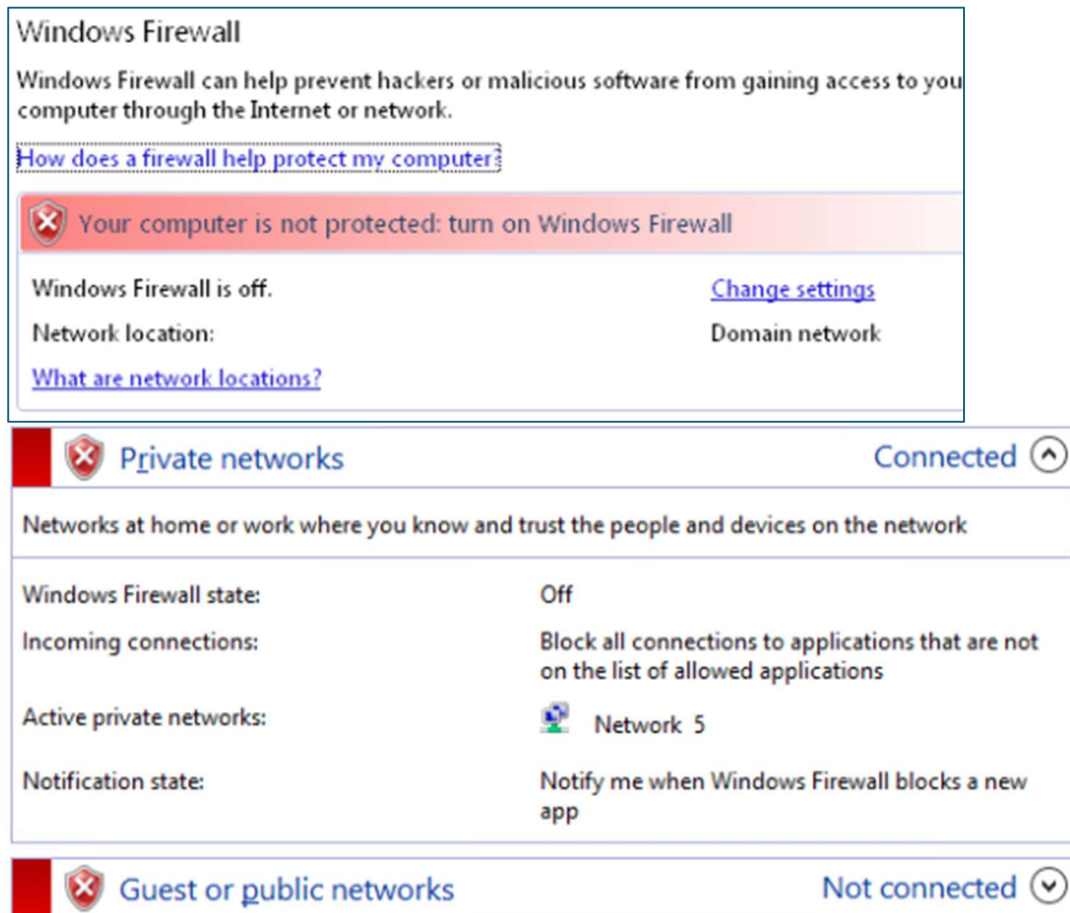
In internal backtrack:

1. Added user 'student'
2. Ran dpkg-reconfigure openssh-server
3. Verified port 22 is open

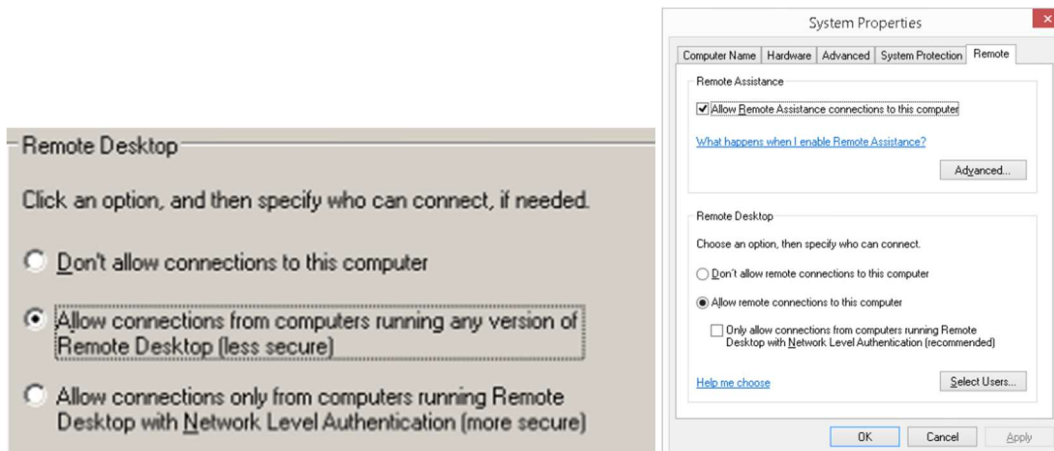
```
root@bt:~# dpkg-reconfigure openssh-server
Creating SSH2 RSA key; this may take some time ..
Creating SSH2 DSA key; this may take some time ..
ssh start/running, process 1865
root@bt:~# netstat -ant
Active Internet connections (servers and establish
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 127.0.0.1:7337          0.0.0.0:*                LISTEN
tcp        0      0 0.0.0.0:21              0.0.0.0:*                LISTEN
tcp        0      0 0.0.0.0:22              0.0.0.0:*                LISTEN
```

In windows 2008 and 8:

1. Disabled firewall

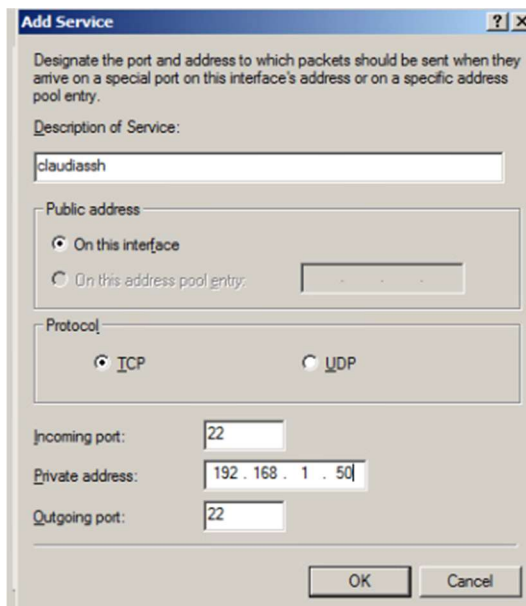


2. Enabled remote desktop:



In Windows 2008 Firewall

1. Set up ssh: private address is set to Backtrack Internal IP



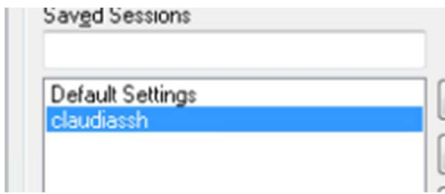
From backtrack external, I could confirm that I could connect to Backtrack internal through ssh:

Ssh `student@216.1.1.1` (where student is the user that we manually added in Backtrack internal – IP is the firewall's IP)

```
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.
```

```
student@bt:~$
```

Also, from windows 7 external box, I opened an ssh connection from putty:



Claudiassh has the following info: 216.1.1.1 and port 22

Log in with the student user we created (pw hacker)

A screenshot of a terminal window titled 'student@bt: ~'. The window shows the output of an SSH login session. The user 'student' has successfully logged in from IP 216.1.1.1. The terminal displays system information, including the kernel version (Linux bt 3.2.6), the date and time (Thu Oct 2 18:31:50 EDT 2025), and system statistics such as system load (0.0), memory usage (12%), and processes (111). It also shows that there is 1 zombie process and provides a link to the Canonical Landscape website for system management. The prompt 'student@bt:~\$' is visible at the bottom, indicating the user is now at the shell.

```
student@bt: ~
login as: student
student@216.1.1.1's password:
Linux bt 3.2.6 #1 SMP Fri Feb 17 10:40:05 EST 2012 i686 GNU/Linux

  System information as of Thu Oct  2 18:31:50 EDT 2025

  System load:  0.0                Processes:           111
  Usage of /:   58.0% of 19.06GB    Users logged in:    2
  Memory usage: 12%                IP address for eth2: 192.168.1.50
  Swap usage:   0%

=> There is 1 zombie process.

  Graph this data and manage this system at https://landscape.canonical.com/
Last login: Thu Oct  2 18:26:35 2025 from 216.1.1.100
student@bt:~$
```

2. Set up port 50000 to go to 192.168.1.200 port 50000 – this IP is going to Windows 8

Add Service [?] [X]

Designate the port and address to which packets should be sent when they arrive on a special port on this interface's address or on a specific address pool entry.

Description of Service:
50000

Public address:
☒ On this interface
☐ On this address pool entry: []

Protocol:
☒ TCP ☐ UDP

Incoming port: 50000
Private address: 192 . 168 . 1 . 200
Outgoing port: 50000

OK Cancel

3. Set up port 50001 to go to 192.168.1.200 port 50001 – this IP is going to Windows 8

Add Service [?] [X]

Designate the port and address to which packets should be sent when they arrive on a special port on this interface's address or on a specific address pool entry.

Description of Service:
50001

Public address:
☒ On this interface
☐ On this address pool entry: []

Protocol:
☒ TCP ☐ UDP

Incoming port: 50001
Private address: 192 . 168 . 1 . 200
Outgoing port: 50001

OK Cancel

Verified from backtrack external that port22, 50000 and 50001 are the only ports showing in firewall:

Enter command in ext backtrack: nmap -sS 216.1.1.1 (firewall IP)

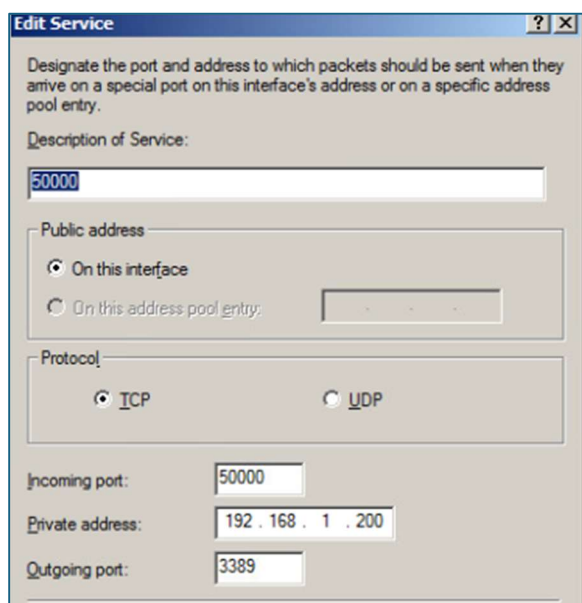
```
root@bt:~# nmap -sS 216.1.1.1

Starting Nmap 6.01 ( http://nmap.org ) at 2025-10-02 17:22 EDT
Nmap scan report for 216.1.1.1
Host is up (0.00034s latency).
Not shown: 997 filtered ports
PORT      STATE SERVICE
22/tcp    open  ssh
50000/tcp  closed ibm-db2
50001/tcp  closed unknown
MAC Address: 00:50:56:9C:8A:94 (VMware)
```

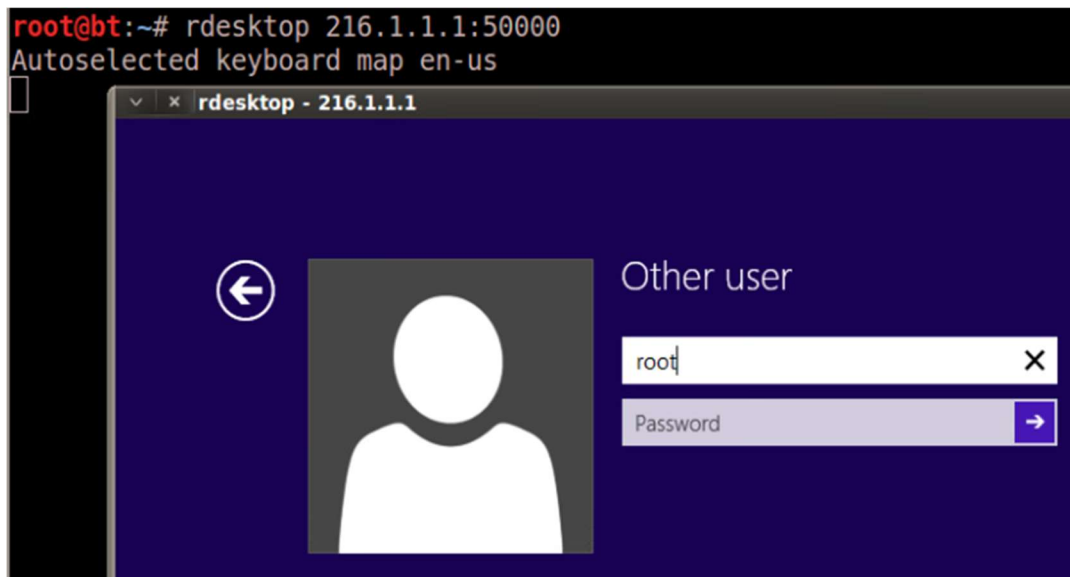
Try to implement the following: **Take your time**. Chart out what you need to do.

A. Connect to 192.168.1.100 via RDP from the external systems--> rdesktop 216.1.1.1:50000

I was running into some issues because my setup was incomplete. I updated my port forwarding setup in windows firewall to send incoming 50000 traffic to 192.168.1.200 to port 3389.

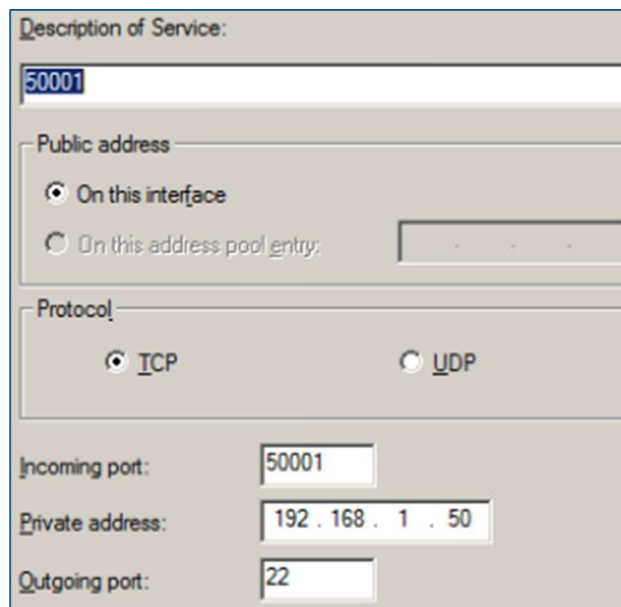


From backtrack external, launched rdp and loaded rdp connection to windows 8 machine:



B. Connect to 192.168.1.50 via SSH from the external system--> SSH hacker@216.1.1.1 - p50001

I updated my port forwarding setup in windows firewall to send incoming 50001 traffic to 192.168.1.150 to port 22.



I could not make a connection with the username hacker but I utilized student instead:

```

root@bt:~# ssh student@216.1.1.1 -p50001
student@216.1.1.1's password:
Linux bt 3.2.6 #1 SMP Fri Feb 17 10:40:05 EST 2012 i686 GNU/Linux

System information as of Thu Oct  2 19:42:35 EDT 2025

System load:  0.25                Processes:            114
Usage of /:   58.0% of 19.06GB    Users logged in:     2
Memory usage: 13%                IP address for eth2: 192.168.1.50
Swap usage:   0%

=> There is 1 zombie process.

Graph this data and manage this system at https://landscape.canonical.com/
Last login: Thu Oct  2 18:52:53 2025 from 216.1.1.200
student@bt:~$

```

C. From Backtrack external, try to scan 192.168.1.100, 200 and 50

Some nmap scans cannot be executed because of lack of root privileges. But I found the following scan that could be run without root privileges:

Nmap -sT -Pn 192.168.1.100 (executed same scan for .200 and .50)

```

student@bt:~$ nmap -sT -Pn 192.168.1.100

Starting Nmap 6.01 ( http://nmap.org ) at 2025-10-02 19:47 EDT
Nmap scan report for 192.168.1.100
Host is up (0.000068s latency).
Not shown: 973 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http

```

```
student@bt:~$ nmap -sT -Pn 192.168.1.200

Starting Nmap 6.01 ( http://nmap.org ) at 20
Nmap scan report for 192.168.1.200
Host is up (0.000086s latency).
Not shown: 988 closed ports
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
1025/tcp  open  NFS-or-IIS
1026/tcp  open  LSA-or-nterm
```

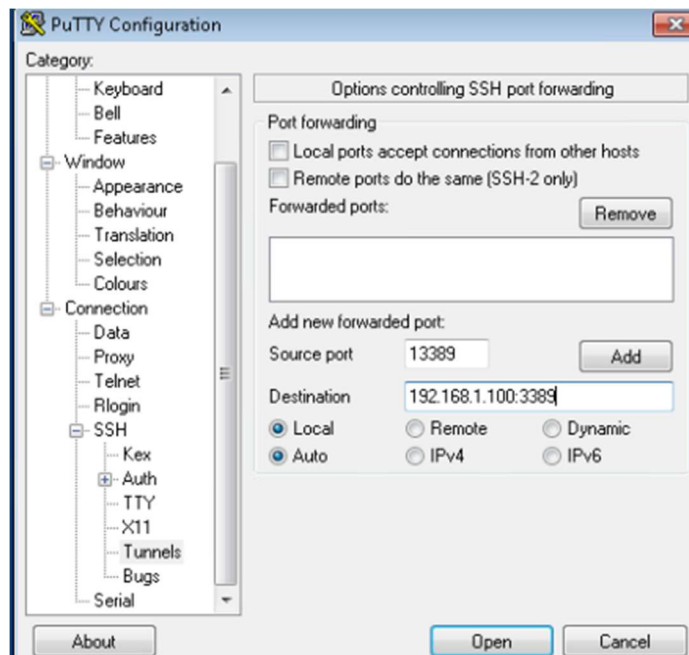
```
student@bt:~$ nmap -sT -Pn 192.168.1.50

Starting Nmap 6.01 ( http://nmap.org ) at
Nmap scan report for 192.168.1.50
Host is up (0.00018s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
```

D. From the Windows 7 external box, try to do the below **"at the same time"**:

- access the windows 2008 web interface
- access the windows 2008 RDP

in windows 7 external box, set up tunneling through putty:



Loaded connection through putty and logged on with credentials.

```
student@bt: ~
login as: student
student@216.1.1.1's password:
Linux bt 3.2.6 #1 SMP Fri Feb 17 10:40:05 EST 2012 i686 GNU/Linux

System information as of Thu Oct  2 18:40:44 EDT 2025

System load:  0.0          Processes:           111
Usage of /:   58.0% of 19.06GB Users logged in:        2
Memory usage: 12%          IP address for eth2: 192.168.1.50
Swap usage:   0%

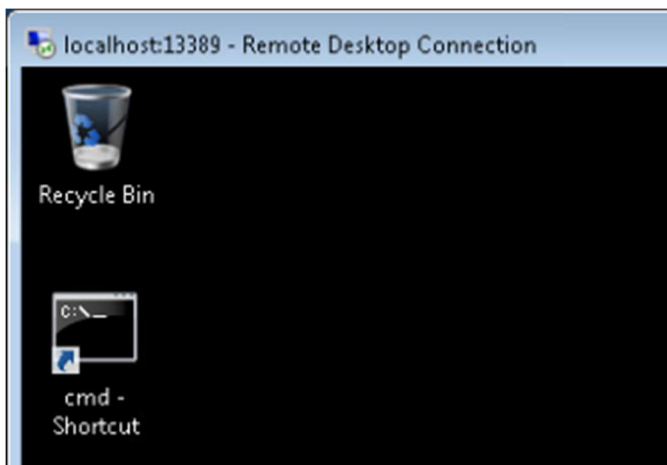
=> There is 1 zombie process.

Graph this data and manage this system at https://landscape.canonical.com/
Last login: Thu Oct  2 18:31:50 2025 from 216.1.1.200
student@bt:~$
```

Don't exit from putty. Minimize putty and while putty is open, you then open remote desktop and enter localhost:13389 and enter Windows 2008 credentials (administrator: P@ssw0rd)



- access the windows 8 via RDP
 closed putty
 open putty again
 under tunnelling replace info with windows 8 info: L13389 192.168.1.200:389
 log on to putty with firewall credentials: student/hacker
 left putty window open
 opened remote desktop; entered localhost:13389 – entered student/password which are the credentials to the windows 8 box. Able to load RDP connection:



- access the backtrack internal ftp server and copy nc.exe from BT-internal to you windows 7 box

Part C: SierraLab Linux: DO NOT EXCEED THE SCOPE OF THIS LAB OR YOU WILL RECIEVE AN AUTOMATIC F FOR THIS LAB

SSH using Putty and your private key with your credentials onto 207.62.230.146, port 2222. Once in, ssh to the Linuxbox.com and answer the below questions.

For the below exercise, utilize the skills that you learned this week to tunnel your website with Putty (Dynamic Port Forwarding)

For every website in the below subnets, try to find the authentication portion of the website (screenshot it). **You will not be able to access some websites via the Gui. You can access all websites via Cli.**

Setup:

1. set up putty with tunnel – load regular connection, go to tunneling
Port 8180 – selected dynamic port
Entered no IP address just the D8180
Added the connection
2. verified connection
opened cmd in my windows PC
ran netstat -ant command
identified the following as open port:

```
TCP    127.0.0.1:8180
```

3. Firefox connection

Set up the following proxy settings found under network settings:

Connection Settings

Configure Proxy Access to the Internet

☐ No proxy

☐ Auto-detect proxy settings for this network

☐ Use system proxy settings

☒ Manual proxy configuration

HTTP Proxy Port

☐ Also use this proxy for HTTPS

HTTPS Proxy Port

SOCKS Host Port

☐ SOCKS v4 ☒ SOCKS v5

☐ Automatic proxy configuration URL

Reload

No proxy for

OK Cancel

For this lab, use tools like dirb, Dirsearch, or Gobuster

172.16.99.0/24

Found the following Ips with port 80 open:

172.16.99.1 -pfsense, tried u admin and pw password

172.16.99.2 – apache2 debian default page

172.16.99.4 – windows server / internet information services

172.16.99.14 – could not load it in firefox

172.16.99.17 – pentesterlab.com

172.16.99.50 – pfsense

10.6.6.0/24 LAN2

Found the following Ips with port 80 open:

10.6.6.1

10.6.6.13

10.6.6.23

10.6.6.100

Could not open a browser for these IPs

10.5.5.0/24

Found the following Ips with port 80 open:

10.5.5.1

10.5.5.12

10.5.5.14

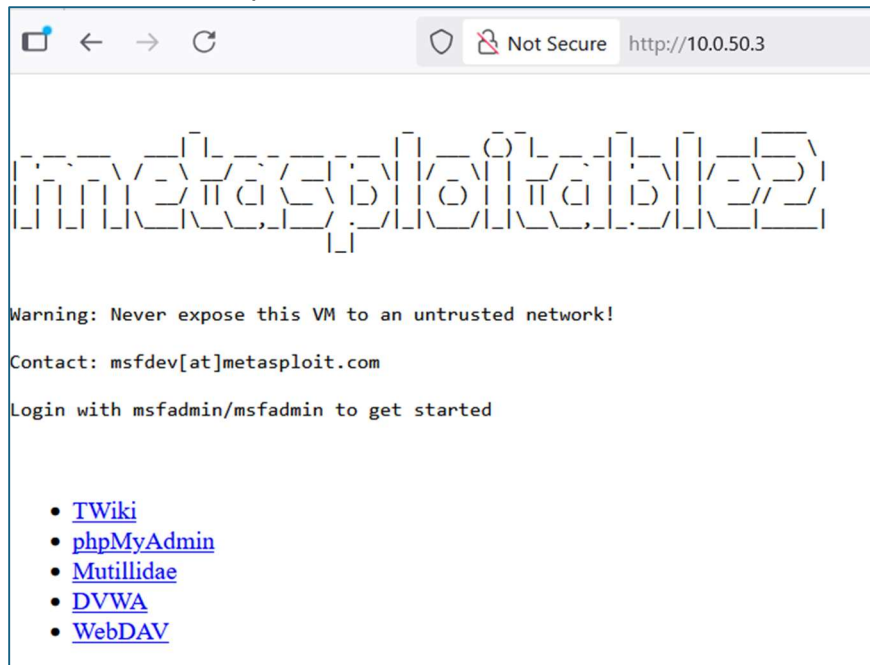
Could not open a browser for these IPs

10.0.50.0/24

Found the following Ips with port 80 open:

10.0.50.1 – pfsense

10.0.50.3 – metasploitable



After identifying 10.0.50.3 as metasploitable, I did a nmap version scan to identify what ports were open:

```
(itl45student@ Kali) - [~]
$ nmap -sV -p 21,22,23,25,80,139,445,3306,5432 10.0.50.3
Starting Nmap 7.94 ( https://nmap.org ) at 2025-10-09 17:11 UTC
Nmap scan report for 10.0.50.3
Host is up (0.00095s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org
Nmap done: 1 IP address (1 host up) scanned in 12.98 seconds
```

I identified ftp as open and so I decided to try to log in to it.

```
(itl45student@ Kali)-[~]  
$ ftp 10.0.50.3  
Connected to 10.0.50.3.  
220 (vsFTPd 2.3.4)  
Name (10.0.50.3:itl45student): msfadmin  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> █
```

I was able to log in with u: msfadmin and pw: msfadmin

I was also able to log in using telnet, same username and password

```
(itl45student@ Kali)-[~]  
$ telnet 10.0.50.3  
Trying 10.0.50.3...  
Connected to 10.0.50.3.  
Escape character is '^]'.  
  
Warning: Never expose this VM to an untrusted network!  
  
Contact: msfdev[at]metasploit.com  
  
Login with msfadmin/msfadmin to get started  
  
metasploitable login: msfadmin  
Password:  
Last login: Thu Sep 30 21:27:24 EDT 2021 from 192.168.1.9 on pts/1  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
No mail.  
msfadmin@metasploitable:~$ █
```

10.0.50.4
10.0.50.6
10.0.50.7
10.0.50.8
10.0.50.9
10.0.50.10
10.0.50.14
10.0.50.16
10.0.50.17